

보안 위협 분석 리포트

AI/LLM 생태계 공급망 공격

— 잠복형 사이버 위협의 부상과 대응 전략 —

보안 민감 — 내부 배포용

LiteLLM TeamPCP 공급망 공격 사례 분석 (2026-03-24)

Claude Code Plugin · PyPI 생태계 · 국가 및 테러 단체 위협

Dennis Kim

gameworker@gmail.com

<https://github.com/gameworkerkim>

발행일: 2026년 3월 25일

1. 개요 및 Executive Summary

본 리포트는 2026년 3월 24일 발생한 LiteLLM PyPI 공급망 공격(TeamPCP)을 기점으로, AI/LLM 생태계를 대상으로 한 공급망 공격의 현황, 역사적 선례, 그리고 향후 위협 전망을 종합 분석한다. 특히 Claude Code Plugin, Obsidian AI 플러그인 등 LLM 기반 개발 도구의 급속한 보급에 따라, 기존 npm/GitHub 생태계 공격보다 훨씬 치명적이고 파급력이 큰 공격이 잠복형(dormant)으로 진행될 가능성을 경고한다.

구분	내용
공격 명칭	TeamPCP LiteLLM PyPI 공급망 공격
발생일	2026-03-24 (UTC)
영향 버전	litellm v1.82.7, v1.82.8 (악성)
노출 시간	약 3시간 (PyPI 게시 후 제거까지)
공격 벡터	Trivy CI/CD 침해 → PyPI 토큰 탈취 → 악성 패키지 배포
페이로드	SSH 키·API 토큰·클라우드 자격증명 탈취, K8s 횡이동, systemd 백도어
영향 생태계	Python/PyPI 전용 (npm/JS 무관)
위협 그룹	TeamPCP (국가 연계 의심)

2. LiteLLM TeamPCP 공급망 공격 상세 분석

2.1 공격 타임라인

2026년 3월 24일, 위협 그룹 TeamPCP는 PyPI(Python Package Index)에 악성 litellm 패키지를 업로드했다. 이 공격은 단순한 패키지 위변조가 아닌, 신뢰할 수 있는 CI/CD 인프라를 침해하는 정교한 다단계 공급망 공격이다.

단계	내용	비고
1단계	Trivy 보안 스캐너 CI/CD 파이프라인 침해	인프라 신뢰 체계 붕괴
2단계	BerriAI/litellm 저장소의 PyPI 발행 토큰 탈취	자격증명 탈취
3단계	악성 litellm v1.82.7 / v1.82.8 PyPI 업로드	정상 릴리즈로 위장
4단계	자동화 의존성 업데이트(Dependabot 등)로 전파	약 3시간 노출
5단계	PyPI 팀 신고 접수 → 패키지 제거	제거까지 다운로드 발생

2.2 악성 페이로드 분석

삽입된 악성 코드는 단순한 정보 수집을 넘어, 장기적 잠복과 횡이동을 목적으로 설계된 APT(Advanced Persistent Threat) 수준의 페이로드였다.

- SSH 공개 키 삽입: 공격자 SSH 키를 ~/.ssh/authorized_keys 에 등록하여 영구 원격 접근 확보
- API 토큰 및 클라우드 자격증명 탈취: AWS, GCP, Azure 환경변수 및 ~/.aws/credentials, ~/.config/gcloud 수집
- Kubernetes 횡이동: 클러스터 내 서비스 어카운트 토큰을 이용한 lateral movement
- systemd 백도어 서비스 등록: sysmon.service 위장 백도어로 재부팅 후에도 지속
- C2(Command & Control) 비콘: 공격자 서버로 주기적 체크인 및 명령 수신

⚠ 치명적 위험 요소

- 개발자 환경에서 탈취된 API 키가 프로덕션 시스템에 직접 연결
- LLM API 키(OpenAI, Anthropic, Google) 탈취 시 AI 서비스 무단 사용 및 프롬프트 감청 가능
- K8s 환경에서 클러스터 전체 침해로 확장될 수 있는 횡이동 역량
- systemd 서비스 등록으로 시스템 재시작 후에도 백도어 유지

3. 역사적 선례: npm/GitHub 생태계 공급망 공격

LiteLLM 공격을 이해하기 위해서는 이전 생태계에서 발생한 공급망 공격 패턴을 이해할 필요가 있다. 다음은 주요 선례 사건들이다.

3.1 event-stream 사건 (2018, npm)

2018년 11월, 약 200만 주간 다운로드를 기록하던 npm 패키지 event-stream에 악성 코드가 삽입되었다. 공격자는 패키지 유지관리자로부터 소유권을 이전받은 뒤 flatmap-stream이라는 의존성을 통해 악성 코드를 숨겼다.

- 타겟: Copay 비트코인 지갑 앱 사용자
- 페이로드: 개인 지갑 키 및 잔액 탈취
- 노출 기간: 약 2개월 (발견 전까지)
- 교훈: 관리자 신뢰 이전(Trust Transfer)이 공격 벡터로 활용됨

3.2 ua-parser-js 하이재킹 (2021, npm)

주당 수천만 다운로드를 기록하는 ua-parser-js 패키지가 npm 계정 탈취를 통해 3개의 악성 버전(0.7.29, 0.8.0, 1.0.0)으로 교체되었다.

- 페이로드: 암호화폐 채굴 코드(cryptominer) + 패스워드/토큰 탈취
- 영향: Facebook, Microsoft 등 Fortune 500 기업 CI/CD 파이프라인 직접 영향
- 노출 시간: 약 4시간

- 교훈: 인기 패키지일수록 자동 신뢰로 인해 피해 규모가 기하급수적으로 증가

3.3 colors.js / faker.js 사보타주 (2022, npm)

패키지 원저자 Marak Squires가 자신의 패키지에 의도적으로 무한 루프 코드를 삽입하여 수 천 개의 서비스를 마비시켰다. 공급자 원저자 자신이 무기화될 수 있음을 보여준 사례다.

- 영향: AWS CDK, 수천 개의 오픈소스 프로젝트 즉각 장애
- 교훈: Insider Threat — 원저자조차 신뢰할 수 없는 시대의 도래

3.4 XZ Utils 백도어 (2024, Linux)

2024년 발견된 XZ Utils 사건은 공급망 공격의 새로운 차원을 보여준다. 공격자 'Jia Tan'은 약 2년간 오픈소스 기여자로 활동하며 신뢰를 쌓은 뒤 liblzma 라이브러리에 SSH 인증을 우회하는 백도어를 삽입했다.

- 잠복 기간: 약 2 년 (2022~2024 년)
- 영향: Debian, Fedora, Arch 등 주요 Linux 배포판의 SSH 서버 직접 침해
- 국가 행위자 의심: 정교함과 인내심으로 보아 국가 지원 APT 그룹으로 추정
- 교훈: 장기 잠복형 공격(Slow-burn APT)이 오픈소스 생태계에서 현실화됨

3.5 SolarWinds Orion 공급망 공격 (2020)

러시아 SVR 산하 APT29(Cozy Bear)가 SolarWinds의 빌드 시스템에 침투하여 18,000개 이상의 조직에 악성 소프트웨어를 배포한 역사상 가장 심각한 공급망 공격 중 하나이다.

- 잠복 기간: 약 14 개월 (2019 년 10 월 ~ 2020 년 12 월 발견)
- 피해: 미국 정부기관(국방부, 재무부, DHS 등) 및 Fortune 500 기업 포함
- 공격 방식: 정상 소프트웨어 업데이트에 SUNBURST 백도어 삽입
- 교훈: 신뢰받은 소프트웨어 배포 채널이 최고의 공격 벡터

사건명	연도	생태계	잠복 기간	피해 규모
-----	----	-----	-------	-------

event-stream	2018	npm	~2개월	중
ua-parser-js	2021	npm	~4시간	대
XZ Utils	2024	Linux	~2년	치명적
SolarWinds	2020	엔터프라이즈	~14개월	치명적
LiteLLM (TeamPCP)	2026	PyPI/AI	~3시간	조사 중

4. AI/LLM 생태계 공격이 더 치명적인 이유

기존 npm/PyPI 공급망 공격도 충분히 위험했으나, LLM 생태계를 겨냥한 공격은 구조적·기능적 특성으로 인해 훨씬 높은 폭발력(Blast Radius)을 가진다. 다음 다섯 가지 핵심 이유를 분석한다.

4.1 LLM 도구는 과도한 권한(Excessive Privilege)으로 실행된다

Claude Code, Cursor, Copilot 등 AI 코딩 어시스턴트는 설계상 파일 시스템 읽기/쓰기, 터미널 실행, 환경변수 접근, 네트워크 요청 등 매우 광범위한 권한을 필요로 한다.

- 일반 npm 라이브러리: 특정 기능에 제한된 권한
- LLM 플러그인/MCP 서버: 개발자 로컬 환경 전체에 대한 접근 권한
- 공격자가 LLM 도구를 통해 코드베이스, SSH 키, API 토큰, 클라우드 자격증명을 한 번에 탈취 가능

→ 즉, LLM 도구에 삽입된 단 하나의 백도어가 기존 공격의 10배 이상의 정보를 한 번에 탈취할 수 있다.

4.2 AI 도구는 "자동 신뢰" 문화가 형성되어 있다

개발자들은 AI 도구의 편의성에 의존하면서 플러그인 설치 시 보안 검토를 생략하는 경향이 강하다. 특히:

- Claude Code Extension, MCP 서버 등은 설치 즉시 높은 권한으로 실행
- "AI가 추천한 패키지"에 대한 심리적 신뢰가 보안 감각을 무디게 함
- 빠른 생산성 추구로 인해 lock 파일 고정, 버전 검증 등 기본 보안 절차 생략 빈번

4.3 LLM 자체를 통한 "AI 독살(AI Poisoning)" 공격 가능

LLM 생태계 공격은 단순히 코드를 통한 공격에 그치지 않는다. 악성 플러그인이 LLM의 컨텍스트에 직접 접근하거나 수정할 경우:

- Prompt Injection: 악성 코드가 LLM 에 악의적인 지시를 주입
- Training Data Poisoning: LLM 의 파인튜닝 데이터에 백도어 삽입
- Model Exfiltration: 독점 파인튜닝 모델 가중치 탈취
- Context Window 감청: LLM 에 전달되는 민감한 코드·데이터·비밀 감청

→ 이는 코드 레벨 공격이 아닌 인텔리전스 레벨 공격으로, 방어 탐지가 극도로 어렵다.

4.4 CI/CD와의 심층 통합으로 횡이동 범위가 극대화

LiteLLM, LangChain, AutoGPT 등 LLM 프레임워크는 현대적 CI/CD 파이프라인에 깊이 통합되어 있다.

- GitHub Actions, Jenkins, GitLab CI 에서 LLM 기반 코드 리뷰·테스트 자동화 사용 증가
- 침해된 LLM 도구가 CI/CD 파이프라인을 통해 프로덕션 환경으로 직접 연결
- K8s 클러스터 내 LLM 워크로드 침해 시 전체 마이크로서비스 환경 노출

4.5 LLM 생태계의 생명력: 급속 성장하는 공격 표면

2024년부터 AI 코딩 도구 생태계는 폭발적으로 성장했으며, 이는 곧 공격 표면(Attack Surface)의 급격한 확장을 의미한다.

지표	2023	2026 예상
월간 litellm PyPI 다운로드	~50만	~2,000만 이상
Claude Code 일 활성 사용자	소수 얼리어답터	수백만
MCP 서버/플러그인 수	수십 개	수천 개
LLM 연동 CI/CD 파이프라인	실험적	산업 표준화 진행

5. 국가 및 테러 단체의 잠복형 공격 시나리오

XZ Utils 사건에서 확인된 것처럼, 국가 지원 APT 그룹들은 이미 오픈소스 생태계에서 수년간의 잠복형 공격을 수행할 역량을 보유하고 있다. AI/LLM 생태계는 이들에게 훨씬 매력적인 타겟이다.

5.1 잠복형(Slow-burn) 공격 시나리오

다음은 국가 행위자가 AI 생태계를 대상으로 수행할 수 있는 현실적인 잠복형 공격 시나리오이다.

시나리오 A: 오픈소스 기여자 위장 (XZ Utils 방식)

- Step 1: 공격자가 유명 MCP 서버(예: claude-mcp-filesystem) 저장소에 수개월간 정상 기여
- Step 2: 신뢰 관계 구축 후 maintainer 권한 획득
- Step 3: 마이너 릴리즈에 탐지 어려운 백도어 삽입 (난독화, 조건부 실행)
- Step 4: Claude Code 사용자 전체로 자동 배포 후 장기 잠복
- Step 5: 지정된 타겟(정부 계약 개발사, 방산업체 등)에서만 페이로드 활성화

시나리오 B: PyPI/npm 패키지 하이재킹 (LiteLLM 방식 심화)

- Step 1: 인기 LLM 프레임워크의 CI/CD 토큰 탈취
- Step 2: 악성 버전을 취약한 시간대(주말, 공휴일)에 업로드
- Step 3: Dependabot 등 자동화 도구로 수천 개 프로젝트에 전파
- Step 4: 탈취된 클라우드 자격증명으로 프로덕션 인프라 침해

시나리오 C: AI 모델 공급망 공격 (차세대 위협)

- Step 1: HuggingFace 등 모델 허브에 백도어가 삽입된 파인튜닝 모델 업로드

- Step 2: 정상 모델로 위장 후 기업의 RAG/파인튜닝 파이프라인에 통합
- Step 3: 특정 프롬프트 패턴 감지 시 민감 데이터 유출 또는 잘못된 응답 생성
- Step 4: 금융·의료·국방 분야의 LLM 기반 의사결정 시스템 조작

5.2 AI 생태계가 국가 행위자에게 매력적인 이유

i 전략적 가치 분석

- 개발자 환경 침해 → 소스코드 탈취: 기업·정부 기밀 코드베이스에 접근
- API 키 탈취 → AI 서비스 악용: 대규모 허위정보 생성, 사이버 공격 자동화
- LLM 컨텍스트 감청 → 정보 수집: 기업 전략, 기술 설계, 개인정보 실시간 감청
- 공급망을 통한 대규모 전파: 단일 공격으로 수백만 개발자 동시 감염 가능
- 탐지 회피: AI 도구의 복잡한 의존성 그래프로 인해 악성 코드 은폐 용이

5.3 위협 그룹 유형 및 동기

위협 행위자	주요 타겟	예상 공격 방식	잠복 가능 기간
국가 지원 APT (러시아·중국·북한 등)	정부, 방산, 금융, AI 연구기관	XZ Utils형 장기 오픈 소스 침투	1~3년
사이버 테러 단체	핵심 인프라, 금융 시스템	PyPI/npm 하이재킹	수일~수주
사이버 범죄 조직	암호화폐, 개인 자격 증명	패키지 타이포스쿼팅	수시간~수일
해티비스트	특정 기업·단체	소프트웨어 사보타주	즉각~수주

6. 현재 환경 점검 결과 (2026-03-25 기준)

점검 대상은 Claude Code 연동 플러그인 6종과 Obsidian AI 플러그인 10종, 총 16개 플러그인이다.

6.1 Claude Code 관련 플러그인 점검

플러그인	litellm 의존	버전 상태	판정
Ouroboros v0.25.0	있음 ($\geq 1.80.0$)	lock: 1.82.1 고정	✓ 안전
superpowers	없음	해당 없음	✓ 해당 없음
ralph	없음	해당 없음	✓ 해당 없음
claude-mem	없음	해당 없음	✓ 해당 없음
claude-hud	없음	해당 없음	✓ 해당 없음
obsidian-skills	없음	해당 없음	✓ 해당 없음

6.2 Obsidian 플러그인 점검

점검 대상 Obsidian 플러그인 10개(calendar, claudian, dataview, templater 등) 전체가 JavaScript 기반으로 구현되어 있으며, Python/PyPI 생태계와 무관하다. 따라서 이번 LiteLLM 공격의 영향을 받지 않는다.

6.3 시스템 차원 점검 결과

 현재 환경: 침해 없음 확인

- 시스템 Python 에 litellm 미설치 확인 (pip show litellm → not found)
- 악성 .pth 파일(litellm_init.pth) 미탐지
- 백도어 서비스(sysmon.service) 미등록
- Ouroboros MCP 프로세스 현재 미실행 상태

6.4 자체 점검 명령어

아래 명령어로 즉시 자신의 환경을 점검할 수 있다:

```
# 1. litellm 버전 확인 (1.82.7 또는 1.82.8이면 즉시 제거)
pip show litellm

# 2. 악성 .pth 파일 탐색
find / -name "litellm_init.pth" 2>/dev/null

# 3. 백도어 서비스 확인
systemctl status sysmon.service 2>/dev/null

# 4. authorized_keys 무결성 점검
cat ~/.ssh/authorized_keys | wc -l # 예상치 못한 항목 확인
```

7. 대응 방안 및 보안 권고사항

7.1 즉각 조치 (Immediate Actions)

⚠ 긴급 점검 항목 — 즉시 수행

- pip show litellm → 1.82.7/1.82.8 이면 pip install litellm==1.82.6 또는 pip install litellm --upgrade 즉시 실행
- pip install pip-audit && pip-audit 로 전체 Python 환경 취약점 스캔
- authorized_keys 검토 후 불명확한 공개 키 즉시 제거
- AWS/GCP/Azure API 키 로테이션 (노출 의심 시 즉각 무효화)
- Anthropic API 키, OpenAI API 키 등 LLM API 자격증명 점검

7.2 단기 대응 (1~4주)

1. 의존성 고정(Dependency Pinning): requirements.txt 또는 pyproject.toml 에 litellm==X.X.X 형식으로 정확한 버전 고정

- lock 파일 사용 강제화: pip-compile, poetry.lock, pdm.lock 등 해시 기반 lock 파일 CI/CD 에서 강제 검증
- SBOM(소프트웨어 자재명세서) 생성: 프로젝트 전체 의존성 목록 정기 생성 및 취약점 모니터링
- PyPI 패키지 서명 검증: PEP 740 attestation 또는 Sigstore 를 통한 패키지 무결성 검증
- MCP 서버 권한 최소화: Claude Code 에서 사용하는 MCP 서버의 파일시스템 접근 범위 명시적 제한

7.3 중장기 전략 (1~6개월)

- Zero Trust for AI Tools: LLM 플러그인·도구를 일반 코드와 동일한 보안 기준으로 심사
- AI 도구 샌드박스: Docker/컨테이너 기반 격리 환경에서 Claude Code 등 AI 어시스턴트 실행
- 공급망 위협 인텔리전스 구독: Wiz, Snyk, Socket.dev 등 공급망 보안 특화 서비스 도입
- 오픈소스 기여자 신원 검증 강화: 핵심 LLM 도구 저장소에 Contributor Verification 정책 도입
- AI 도구 사용 감사(Audit) 로그: LLM 플러그인의 네트워크 요청·파일 접근 로그 기록 및 이상 탐지

7.4 조직 차원 거버넌스

영역	권고 사항
정책	AI 도구 도입 전 보안 심사 의무화 (Security Review Gate)
교육	개발자 대상 공급망 공격 인식 교육 정기 실시 (연 2회 이상)
인프라	내부 PyPI/npm 미러 운영 및 허가된 패키지만 사용 정책
모니터링	SBOM 기반 CVE 취약점 실시간 알림 체계 구축
대응	공급망 침해 대응 Runbook 수립 및 정기 훈련

8. 결론

LiteLLM TeamPCP 공격은 AI/LLM 생태계에 대한 정교한 공급망 공격의 시작을 알리는 신호탄이다. 이 공격이 특히 우려스러운 이유는 다음과 같이 요약된다:

- 기존 npm/PyPI 공격보다 훨씬 높은 권한 환경을 대상으로 한다
- AI 도구에 대한 개발자들의 심리적 신뢰가 보안 감각을 무디게 한다
- LLM 컨텍스트 접근을 통한 정보 수집은 탐지가 극도로 어렵다
- 국가 행위자들이 이미 오픈소스 생태계 잠복형 공격을 수행하고 있다
- AI 생태계의 폭발적 성장은 공격 표면을 기하급수적으로 확대하고 있다

XZ Utils 사건이 증명했듯, 국가 지원 APT 그룹은 2년 이상의 잠복 기간을 감수하며 핵심 오픈소스 도구를 침해할 역량을 보유하고 있다. Claude Code Plugin, MCP 서버, LLM 프레임워크는 이들에게 이전 세대 공격보다 수십 배 더 매력적인 타겟이다. 왜냐하면 단 하나의 침해로 수백만 개발자의 환경 전체에 접근할 수 있기 때문이다.

우리는 AI 도구를 '믿을 수 있는 동료'가 아닌 '외부 코드'로 취급하는 보안 문화를 즉시 정착시켜야 한다. 편의성은 중요하지만, 검증되지 않은 신뢰는 가장 위험한 취약점이다.

⚠️ 핵심 메시지

- 지금 당장 litellm 버전을 확인하라 (1.82.7/1.82.8 은 즉시 제거)
- 모든 AI 도구는 설치 전 보안 검토를 거쳐야 한다
- 의존성 고정과 lock 파일 검증은 선택이 아닌 필수다
- 공급망 공격은 이미 시작되었으며, 다음 공격은 더욱 정교할 것이다

참고 자료

- BerriAI/litellm GitHub Issue #24512: LiteLLM 공급망 공격 공식 타임라인
- BerriAI/litellm GitHub Issue #24518: 사고 대응 상세
- Wiz Blog: TeamPCP LiteLLM Supply Chain Attack 분석
- The Hacker News: TeamPCP Backdoors LiteLLM Versions 1.82.7–1.82.8
- CISA Advisory: XZ Utils Backdoor (CVE-2024-3094)
- OpenSSF: Secure Supply Chain Consumption Framework (S2C2F)
- SLSA (Supply chain Levels for Software Artifacts) Framework
- PEP 740 – Index support for digital attestations
- Socket.dev: Real-time supply chain attack detection